

Securing Web Applications the HDIV Way

Holes in Web applications have resulted in the theft of millions of credit cards, apart from major financial and reputational damage for enterprises. They even compromise thousands of machines that visit the websites altered by attackers. This article addresses the need for security from an organisation's viewpoint and suggests a Web application security framework for it.



Organisations are today moving a large number of applications and critical business processes onto the Web, which makes their online presence critical. Embedding more dynamic and interactive features in applications helps the business and simplifies marketing. But this comes with a drawback—more dynamic features also expose application holes, which can be exploited.

The HDIV (HTTP Data Integrity Validator) security framework was mainly created to address the vulnerabilities and application flaws prevalent in Web applications. The reason for its name is that HDIV guarantees the integrity of the data sent in the request, which is not supposed to be modified by the client. It also guarantees data confidentiality by obfuscating the parameter data and the parameters themselves. Note that most vulnerabilities have one thing in common: they can be exploited by entering malicious data in editable and non-editable fields. In the current scenario, almost 80 per cent of attacks are focused on such vulnerabilities (<http://bit.ly/MjRGHw>). Whether cross-site scripting, SQL injection or parameter tampering, most such attacks are performed by tampering with the application's editable fields (textboxes, text areas, etc) or non-editable fields (drop-down lists, radio buttons and read-only fields).

Information contained in these fields can be found in the URL ('querystring'), parameters, cookies and headers.

To mitigate common Web application flaws, there are proper input validation processes that sanitise the user inputs. However, deploying and configuring input validations for each page or request consumes resources and noticeably adds to development time.

One of the major advantages of the HDIV security framework is that it can be implemented even after the application is developed. This saves the development team the headache of modifying application code to implement filters, sanitisers, encoders and stored procedures—and from creating a new security solution for each use case.

Vulnerabilities covered by HDIV

As mentioned, HDIV focuses on vulnerabilities exploitable by modifying data fields in the request, when user-supplied data is processed with improper or no validation.



Note: This list is based on the OWASP TOP 10 list for 2010 of the 'Most Critical Web Application Security Vulnerabilities'.